

Clase 329 — Arquitectura de seguridad empresarial y Zero Trust

Parte: **17 — Profundización para certificaciones** · Fuente: (ISC)² CISSP OSG — *Security Architecture and Engineering* · NIST SP 800-207 (Zero Trust Architecture) · SABSA · TOGAF (Security) 🕒 Duración estimada: **140 min** · Nivel: **Avanzado**

Objetivo

Diseñar seguridad **a nivel de empresa**, no controles sueltos. Esta clase enseña a usar marcos de **arquitectura de seguridad empresarial** —**SABSA** (matriz por capas y trazabilidad al negocio) y la seguridad dentro de **TOGAF**— para conectar los requisitos del negocio con controles concretos, y a aplicar los principios de **defensa en profundidad** y **segmentación**. Sobre esa base se construye el modelo **Zero Trust** según **NIST SP 800-207** (nunca confiar, siempre verificar; acceso por sesión y por política) y su materialización en la red moderna con **SASE**. Cubre *Security Architecture* en CISSP y Security+.

Resultados de aprendizaje

Al finalizar, el alumno podrá:

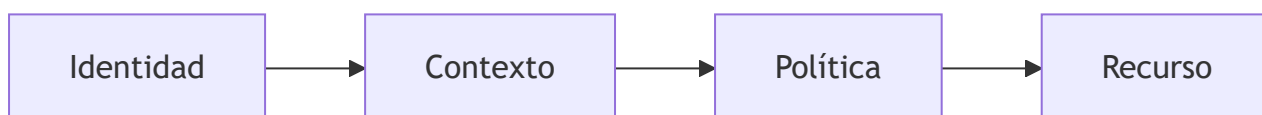
1. **Trazar** requisitos de negocio hasta controles técnicos usando las capas de SABSA.
2. **Aplicar** defensa en profundidad y segmentación (macro y micro) a una arquitectura de referencia.
3. **Explicar** los siete principios y los componentes lógicos (PE/PA/PEP) de Zero Trust de NIST SP 800-207.
4. **Diseñar** un flujo de acceso Zero Trust para una aplicación, con punto de decisión y punto de aplicación de política.
5. **Situar** SASE (SD-WAN + SWG + CASB + ZTNA + FWaaS) como convergencia de red y seguridad en el borde.

Temas

#	Tema	Por qué importa
1	Arquitectura empresarial de seguridad	Alinea la seguridad con los objetivos del negocio
2	SABSA (matriz por capas)	Da trazabilidad de "por qué" a "cómo" y "con qué"
3	TOGAF y la vista de seguridad	Integra la seguridad en la arquitectura corporativa
4	Defensa en profundidad	Capas redundantes: ningún control es único punto de fallo
5	Segmentación macro/micro	Limita el movimiento lateral y reduce el radio de impacto
6	Zero Trust — principios (SP 800-207)	Elimina la confianza implícita de la red
7	Componentes ZT: PE, PA, PEP	Separan decidir de aplicar la política de acceso
8	SASE / ZTNA	Lleva el modelo al usuario remoto y a la nube

Modelo mental y caso de decisión

Zero Trust evalúa cada acceso con identidad, dispositivo, recurso y contexto; no significa ausencia de redes ni confianza cero literal.



Caso razonado. MFA fuerte no compensa dispositivo sin gestión que descarga datos sensibles.

Glosario operativo complementario

Término	Definición
Evidencia	Información cuya procedencia y relación con un criterio pueden revisarse.
Supuesto	Condición declarada de la que depende una conclusión.
Riesgo residual	Exposición que permanece después del tratamiento.

Criterio de dominio

El alumno demuestra dominio cuando explica el diagrama, resuelve el caso con evidencia, declara límites y puede defender por qué su decisión cambia si cambia un supuesto.

Definiciones y características

- **Arquitectura de seguridad empresarial (ESA):** disciplina que estructura los controles de seguridad de toda la organización de forma coherente y alineada al negocio. Característica clave: piensa en **sistema**, no en dispositivos aislados.
- **SABSA:** marco cuya **matriz** cruza seis capas (contextual, conceptual, lógica, física, de componentes y operacional) con las preguntas *qué, por qué, cómo, quién, dónde, cuándo*. Característica clave:

trazabilidad de cada control hasta un requisito de negocio.

- **TOGAF (seguridad):** método de arquitectura empresarial (ADM) en el que la seguridad es una preocupación transversal a las arquitecturas de negocio, datos, aplicación y tecnología. Característica clave: integra seguridad en el ciclo de arquitectura, no como añadido.
- **Defensa en profundidad:** aplicación de **múltiples capas** de controles independientes (perímetro, red, host, aplicación, datos, identidad) para que el fallo de una no comprometa el conjunto. Característica clave: redundancia deliberada.
- **Segmentación:** división de la red/recursos en zonas con control de tráfico entre ellas.
Macrosegmentación (zonas/VLAN) y **microsegmentación** (política por carga de trabajo). Característica clave: contiene el movimiento lateral.
- **Zero Trust (ZT):** modelo que **elimina la confianza implícita**: cada solicitud de acceso se autentica, autoriza y cifra por sesión, según identidad, estado del dispositivo y contexto. Característica clave: "nunca confiar, siempre verificar".
- **PDP/PEP (PE, PA, PEP):** en SP 800-207, el **Policy Engine (PE)** decide, el **Policy Administrator (PA)** establece/termina la sesión y el **Policy Enforcement Point (PEP)** aplica el acceso frente al recurso. Característica clave: separan la **decisión** de la **aplicación**.
- **SASE:** convergencia en la nube de red (**SD-WAN**) y seguridad (**SWG, CASB, ZTNA, FWaaS**) entregada como servicio en el borde. Característica clave: acerca la política al usuario/recurso, no al datacenter.
- **ZTNA:** acceso a aplicaciones basado en identidad y política, sin exponer la red (reemplaza la VPN de "todo o nada"). Característica clave: acceso al **recurso**, no a la red.

Herramientas y preparación

Ejercicio **de diseño/arquitectura** — se trabaja con diagramas y políticas, no con explotación:

- **Herramienta de diagramación:** draw.io/diagrams.net, Excalidraw o Visio para la arquitectura de referencia y los flujos de acceso.
- **Plantilla SABSA:** hoja con la matriz de seis capas para trazar un requisito de negocio hasta controles.
- **Documentos base:** **NIST SP 800-207** (ZTA) y, como complemento, la guía de migración **NIST SP 1800-35**; el modelo de madurez **CISA Zero Trust Maturity Model**.
- **Laboratorio opcional (identidad):** un IdP (Keycloak/Entra ID de pruebas) para modelar autenticación basada en políticas y acceso condicional.
- **Laboratorio opcional (segmentación):** reglas de firewall/ `nftables` o etiquetas de microsegmentación en un entorno de laboratorio propio.

Nota: cualquier prueba de segmentación o políticas de acceso se hace en **entorno propio/aislado**. El objetivo de la clase es el **diseño defensivo**, no probar accesos sobre sistemas ajenos.

Laboratorio guiado — Diseñar una arquitectura Zero Trust para una aplicación

Ejercicio aplicado: partes de una app corporativa expuesta con VPN clásica y la rediseñas bajo Zero Trust, con trazabilidad SABSA.

1. **Levanta el contexto (SABSA capa contextual).** Describe el negocio: qué app, quién la usa (empleados, terceros), qué datos maneja y qué riesgo importa. Anota el requisito de negocio en una

frase.

2. **Dibuja la arquitectura actual.** Diagrama el estado "castillo y foso": VPN → red plana → app. Marca dónde hay **confianza implícita** (todo el que entra a la VPN alcanza todo).
3. **Aplica defensa en profundidad.** Identifica las capas de control faltantes (identidad, dispositivo, red, aplicación, datos) y qué control pondrías en cada una.
4. **Segmenta.** Propón macrosegmentación (separar la app de la red general) y microsegmentación (aislar la carga de trabajo de su base de datos). Define qué tráfico se permite explícitamente; el resto se deniega.
5. **Modela el flujo Zero Trust (SP 800-207).** Dibuja el acceso: sujeto + dispositivo → **PEP** → consulta al **PE/PA** que evalúa política (identidad, MFA, postura del dispositivo, contexto) → concede sesión **por recurso** y cifrada. Señala explícitamente PE, PA y PEP.
6. **Escribe la política.** Redacta 4–6 reglas de acceso basadas en atributos (p. ej. "usuario del grupo Finanzas + dispositivo gestionado + MFA reciente → acceso solo a la app de facturación por 8 h").
7. **Sustituye la VPN por ZTNA.** Reemplaza el acceso "a la red" por acceso "al recurso"; documenta cómo el usuario remoto ya no ve la red interna.
8. **Encaja el SASE.** Sitúa los componentes (SWG, CASB, ZTNA, FWaaS) en el borde y explica qué resuelve cada uno para el usuario remoto y el tráfico a SaaS.
9. **Traza en la matriz SABSA.** Completa una fila que vaya de la capa contextual (requisito) a la de componentes (producto/control concreto) para demostrar la trazabilidad.
10. **Mide la madurez.** Ubica el diseño en el CISA Zero Trust Maturity Model (tradicional → inicial → avanzado → óptimo) e indica el siguiente paso.

Entregable: diagrama del antes/después, flujo Zero Trust con PE/PA/PEP señalados, conjunto de políticas basadas en atributos, ubicación de los componentes SASE y una fila SABSA completa con nivel de madurez.

Ejercicios

1. Rellena una fila de la matriz SABSA para el requisito "proteger los datos de clientes en la app web".
2. Explica, con un ejemplo, la diferencia entre macrosegmentación y microsegmentación.
3. Enumera los siete principios de Zero Trust de SP 800-207 y da un control que materialice cada uno.
4. Dibuja el flujo PE/PA/PEP para el acceso a una API interna y marca dónde se decide y dónde se aplica.
5. Compara VPN tradicional vs ZTNA en exposición de red, granularidad y experiencia de usuario.
6. Mapea los cinco componentes de SASE a los problemas concretos que resuelve cada uno.

Reto verificable

Reto: entrega el rediseño Zero Trust de una aplicación, trazable al negocio y con política de acceso concreta.

Criterio de aceptación:

- Hay un diagrama **antes/después** que elimina la **confianza implícita** de la red plana/VPN.
- El diseño aplica **defensa en profundidad** (capas de identidad, dispositivo, red, app y datos) y **segmentación** (macro y micro).
- El flujo Zero Trust identifica explícitamente **PE, PA y PEP** conforme a **SP 800-207** y concede acceso **por recurso y por sesión**.

- Existe un conjunto de **políticas basadas en atributos** (identidad + postura del dispositivo + contexto), no reglas por IP.
- Se justifica la sustitución de VPN por **ZTNA** y se ubica el conjunto en un modelo **SASE**, con una fila **SABSA** que da trazabilidad al requisito de negocio.

⚠ Errores comunes

Síntoma / mensaje	Causa y cómo arreglar
"Compramos un producto 'Zero Trust' y ya está"	ZT es una arquitectura , no un producto. Rediseña el flujo de acceso y las políticas, no solo la caja.
"La VPN ya es Zero Trust"	La VPN da acceso a la red entera. ZTNA da acceso al recurso con política por sesión; no son lo mismo.
"Segmentamos por VLAN y basta"	La macrosegmentación no frena el lateral dentro de la zona. Añade microsegmentación por carga de trabajo.
"Las políticas son por IP de origen"	La IP no identifica al sujeto ni su postura. Basa la política en identidad + dispositivo + contexto.
"El diseño no se conecta con ningún requisito"	Falta trazabilidad. Usa la matriz SABSA para ligar cada control a un objetivo de negocio.
"Aplicamos ZT solo a usuarios remotos"	El modelo aplica a todo acceso, también interno. La confianza implícita interna es el vector clásico de lateral.

? Preguntas frecuentes

? ¿Zero Trust reemplaza a la defensa en profundidad? No; la asume y la refina. Zero Trust sigue usando capas de control, pero elimina la suposición de que "dentro" es de fiar. Cada capa verifica la solicitud en lugar de confiar por ubicación de red. Es defensa en profundidad **sin** zona confiable implícita.

? ¿Qué diferencia hay entre SABSA y TOGAF? TOGAF es un método general de arquitectura empresarial (el ciclo ADM) donde la seguridad es transversal. SABSA es un marco **específico de seguridad** con su matriz por capas y su fuerte énfasis en la trazabilidad al negocio. Se usan juntos: TOGAF para la arquitectura global, SABSA para la vista de seguridad.

? ¿SASE y Zero Trust son lo mismo? No. Zero Trust es el **modelo de confianza** (cómo se decide el acceso). SASE es una **arquitectura de entrega** que combina red y seguridad en la nube e incluye ZTNA como uno de sus componentes. Puedes hacer Zero Trust sin SASE, pero SASE es la forma habitual de implementarlo para usuarios distribuidos y SaaS.

? ¿Por dónde se empieza a implantar Zero Trust? Por la identidad y los recursos más críticos. Inventaría sujetos, dispositivos y recursos; fortalece la identidad (MFA, acceso condicional); define un PEP delante de una app piloto; y avanza por el modelo de madurez de CISA en vez de intentar un "big bang" en toda la red.

🔗 Referencias

- NIST. *Zero Trust Architecture* — [SP 800-207](#).

- NIST NCCoE. *Implementing a Zero Trust Architecture* — [SP 1800-35](#).
- The SABSA Institute. *SABSA — Enterprise Security Architecture* — [sabsa.org](#).
- Chapple, Stewart & Gibson. *(ISC)² CISSP Official Study Guide*, 9.^a ed., Sybex — *Security Architecture and Engineering*.
- CISA. *Zero Trust Maturity Model v2.0* — [cisa.gov/zero-trust-maturity-model](#).



Aplicación transversal

Haz una architecture review del [diseño objetivo de custodia](#): identifica policy enforcement points, señales continuas, dominios administrativos y dos fallos comunes capaces de derrotar simultáneamente aprobación y auditoría.



Material descargable

-  [Guía en PDF](#) — versión imprimible de esta clase.
-  [Presentación \(PPTX\)](#) — deck para proyectar en clase.



Clase anterior

[Clase 328 — Gestión de riesgos cuantitativa y continuidad avanzada](#)



Siguiente clase

[Clase 330 — Análisis de código y automatización de seguridad](#)